ISIN 325

Database Security

Defense in depth

Introduction

Our organization has about 1,500 employees. The net sales of the company is approaching 250 million and is expected to grow about 10% each year. Our on-prem SQL servers run Microsoft SQL server, however, HR decided to use a 3rd party server based in the cloud. We need to define and talk about our security within the organization within our constraints. There will be a defense in depth policy defined below.

Physical Security

Our organization should deploy the use of RFID badging on all doors on premises. Not only this, but all restricted access areas should only be given to those who need access to those areas on a regular basis. Not all of I.T. needs access to the data room.

The RFID locks and badges should create sophisticated audit logs of all movement around the building – this is to keep track of who is doing what and when. Surveillance cameras should also be used in restricted access areas for I.T. such as the data room.

We should also use key locked networking racks so if someone is in the data center, they don't have access to start unplugging servers or network cables. This helps to ensure only the people who should have full physical access are the ones touching machines. This also prevents someone from plugging in to the serial port of devices.

Access Control

Our company should also employ the use of a robust password policy. The longer a password is, the harder it is to brute-force. So our company should use a 15 character minimum with the standard upper, lower, number and a special character.

Mulit-Factor is to be used anywhere a password is required. Ideally the MultiFactor is an authenticator app or a USB-token key.

Access to systems should be a per-role basis, such as RBAC, Role-Based Access Control. This ensures there is no access creep as someone moves around a company or moves up. Active Directory would be great for this and cost effective as it comes with using an all windows environment. There should be little to no direct user permissions other than items like personal network drive storage.

Our data should be protected at all times from people leaving the company, so AD access should be stripped away immediately. Disable accounts and reset passwords. There should also be no use of generic accounts – if domain administrator accounts are required one for each user who needs access should be created. This policy allows us to audit who takes actions on what resources and objects in the environment.

A quarterly audit shall be done to verify all accounts that should've been disabled have been. Ideally fully automated for both the audit and disabling of leaving employees.

Data owners should also have full access to determine what can be done with their data. Our job as the data custodians is to uphold the integrity and security of this information to the best of our abilities by following the outlined policies as much as possible.

Data Access

Every user should not have direct table access. All work on the database shall be done on a separate device within the network.

All access to the database will also be using individual accounts, shared accounts for any purpose is a huge liability and creates gap

Views will be employed to prevent access to sensitive information that isn't necessary for the scope of work being done. We can also utilize stored procedures to do this. There shouldn't be any database owner access utilized for every day normal work with a database.

Auditing and Logging policies

All logons to resources in an environment should logged both success and failures. Data access should also be logged depending on the level of data being accessed. We should not be logging the access to some non-vital resources as much as we do our sensitive PII or PCI-DSS type information.

Any permissions or role changes should be logged and or recorded.

Logs should be centralized for data aggregation and when archived be stored off-site. We can utilize SIEM and SOAR to enhance our log analysis and remediation based on the log scans.

Logs should be retained per data regulation based on the type of data being protected.

Errors should also be logged to allow the

Testing

The environment should continually be audited and tested by 3rd parties. This allows us to find and remediate potential issues before a bad actor finds them and keeps us prepared.

We should also do a quarterly tabletop and pretend backup recovery exercise to verify everyone in the environment is aware of their role in a mission critical backup scenario.

At the end of the exercise reflections should be done to help improvement for next time.

Cloud Systems

The provider hosting our cloud systems should be fully vetted for the sensitivity of the data being held on their services. If they aren't compliant, we aren't compliant.

All policies listed for the organization apply to the cloud systems. There should be limited access to these systems.

3rd Party access and VPN/Work From Home

Work from home will be permitted only with company issued devices and written permission from a supervisor. A VPN solution will be provided from the company only. The system will interface with Active Directory and use the same credentials with Multi-factor being utilized as well. A great solution for this would be GlobalProtect.

All Vendors or authorized 3rd party access will be granted temporary access with AD accounts created with only permissions to the tools and resources they are contracted to work on. If the vendors are not on-site they will be given access to a VPN for the time scope they specify on the IT access form. When outside of this scope all accounts and access will be disabled.